

01

22 ABR 2022

11.539 ETH

Akutars NFT

— "11.539 ETH presos para sempre por uma linha"

STATE VARIABLE BUG · CRITICAL

~US\$34M travados permanentemente — sem hack externo, apenas um bug

O QUE ACONTECEU

Akutars era uma coleção NFT de 15.000 peças do artista [Micah Johnson](#), com leilão holandês que arrecadou **11.539 ETH**.

Após o leilão, o contrato deveria **reembolsar** quem pagou acima do preço final. A lógica de refund usava um loop com uma variável de estado.

O bug: [refundProgress](#) era atualizado **antes** de um [require](#) que dependia do valor anterior. O invariante quebrava, e o require sempre falhava.

Ninguém conseguiu ser reembolsado. E como a função de saque do owner também dependia do refund estar completo, **todo o ETH ficou preso para sempre** — sem nenhum atacante envolvido.

03

CONTRATO VULNERÁVEL

```

        .transfer(refundAmounts[i]); } }
        chega aqui payable(refundAddresses[i])
    }
}

```

Lição

Loops de estado devem **preservar os invariantes** dos require seguintes. Teste edge cases com **fuzz testing**.

04

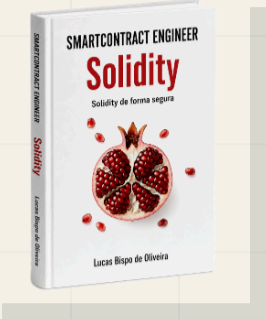
COMO O BUG FUNCIONOU

ESTADO INICIAL`refundProgress = 0, totalBids = 3592`**ITERAÇÃO i = 3591**`refundProgress = 3591 + 1 = 3592`**CHECK**`require(3592 < 3592) → FALSE → REVERT!`**CONSEQUÊNCIA 1**`Último refund nunca processa`**CONSEQUÊNCIA 2**`withdraw() requer refund completo`**RESULTADO**`11.539 ETH trancados PERMANENTEMENTE``Contrato imutável · Sem escape hatch`

VERIFIQUE NA BLOCKCHAIN

Transação com revert
etherscan.io/tx/0x583a5a...3547

Contrato Akutars
etherscan.io/address/0xF42c3...961d



Solbook — Smartcontract Engineer

Aprenda fuzz testing com Foundry para pegar bugs antes do deploy